

Sensibilisation phishing

Mini-SMSI - Aéroport Régional 3CF

Objectif : aider les utilisateurs à reconnaître un email suspect, éviter les clics dangereux et signaler rapidement les tentatives de fraude.

1. C'est quoi le phishing ?

Le phishing est une tentative de manipulation : l'attaquant envoie un email, SMS ou message qui ressemble à une communication normale pour voler un mot de passe, pousser au paiement ou faire ouvrir une pièce jointe malveillante.

Dans une PME ou un aéroport régional, un simple compte compromis peut servir à envoyer de faux messages, accéder à des dossiers internes ou préparer une attaque plus grave.

2. Les signaux d'alerte

Signal	Question à se poser
Urgence ou menace	Me demande-t-on d'agir vite sans réfléchir ?
Lien inhabituel	Le lien correspond-il vraiment au site attendu ?
Pièce jointe inattendue	Est-ce normal de recevoir ce fichier ?
Demande de mot de passe	Un service légitime me demanderait-il cela par email ?
Expéditeur étrange	L'adresse est-elle cohérente avec le nom affiché ?
Fautes ou ton bizarre	Le style ressemble-t-il aux messages habituels ?

3. Le réflexe des 3 secondes

Avant de cliquer, prendre 3 secondes pour vérifier :

Etape	Question	Action
1	Qui m'écrit ?	Vérifier l'adresse exacte de l'expéditeur.
2	Que me demande-t-on ?	Identifier la demande : paiement, mot de passe, fichier, urgence.
3	Est-ce normal ?	Comparer avec le contexte réel : attendais-je ce message ?

4. Que faire si je doute ?

Ne pas cliquer, ne pas répondre, ne pas transférer à des collègues. Signaler au support IT avec l'email original ou une capture d'écran. En cas de clic ou de mot de passe saisi, prévenir immédiatement : plus l'alerte est rapide, plus l'impact peut être limité.

5. Exemple de faux message

Objet : Action urgente - votre compte sera suspendu aujourd'hui

Bonjour,

Votre boîte mail dépasse la limite autorisée. Veuillez confirmer votre mot de passe dans les 2 heures via le lien ci-dessous, sinon votre compte sera supprimé.

<http://microsoft-support-verification.example.com>

Analyse : pression temporelle, demande de mot de passe, lien incohérent, menace de suppression. Ce message doit être signalé.

6. Mini quiz

Question	Bonne réponse attendue
Un manager demande un virement urgent par email. Que faire ?	Vérifier par un canal séparé : téléphone ou message interne connu.
Un email demande ton mot de passe pour 'maintenance'. Que faire ?	Ne jamais donner son mot de passe ; signaler le message.
Tu as cliqué sur un lien suspect mais rien ne s'est passé. Que faire ?	Prévenir le support IT quand même.
La MFA envoie une notification alors que tu ne te connectes pas. Que faire ?	Refuser la demande et signaler immédiatement.

Message clé à retenir

Un bon utilisateur n'est pas quelqu'un qui ne se trompe jamais. C'est quelqu'un qui signale vite quand quelque chose semble anormal.